Security and privacy

Quill is built around the idea that your notes belong to you. This page explains what data Quill collects, how notes are protected on your device and in the cloud, and what you can do to keep a vault secure.

What Quill collects

The desktop app collects almost nothing. It never reads, uploads or analyses the content of your notes unless you turn on sync. There are only two kinds of network traffic when sync is off:

- The daily update check, which sends the app version, operating system and processor type.
- Crash reports, which are sent only if you agree when a crash happens. A crash report includes the stack trace and the list of enabled plugins, but never note content or file names.

Anonymous usage statistics are off by default. If you choose to turn them on under Settings -> Privacy, Quill counts which features are used, such as how often search is opened, without recording any text you type.

Protecting notes on your device

Notes are plain files, so they are exactly as safe as the disk they live on. For laptops, turn on full-disk encryption: BitLocker on Windows, FileVault on macOS, or LUKS on Linux. Quill does not add its own encryption to local files, because doing so would break the promise that your notes are readable by any text editor.

App lock

If other people use your computer, enable the app lock under Settings -> Privacy. Quill then asks for a PIN or your system password every time the window is opened after being idle for the time you choose. The app lock hides the window contents but does not encrypt the files, so someone with access to the disk can still read them.

Encrypted notes

For a few especially sensitive notes, Quill offers encrypted notes. An encrypted note is stored as a file ending in .qenc and can only be read inside Quill after entering its password. Encrypted notes are not indexed for search and cannot be linked from other notes.

Encryption in Quill Cloud

When you sync with Quill Cloud, notes are protected in transit with TLS 1.3. On top of that you can turn on end-to-end encryption for a vault. With end-to-end encryption on, notes are encrypted on your device before upload and the Quill team cannot read them.

How the keys work

End-to-end encryption uses a passphrase that you choose. Quill derives a key from the passphrase with Argon2id, using a random salt stored with the vault, and encrypts each file with AES-256-GCM. The passphrase itself is never sent to the server. A short verification value lets Quill tell you that a passphrase is wrong without revealing anything about the correct one.

Each device needs the passphrase once, when you first connect it to the vault. After that the derived key is kept in the operating system's credential store, such as the Windows Credential Manager or the macOS Keychain.

Losing the passphrase

Because the Quill team never has your key, nobody can recover a lost passphrase. If you forget it, the encrypted copy in the cloud cannot be decrypted. Your notes are still safe on any device that already has them, since local files are not encrypted; you can turn end-to-end encryption off and on again with a new passphrase from such a device. Write the passphrase down and keep it somewhere safe.

What is not encrypted

Even with end-to-end encryption, the server needs some information to sync. It can see how many files a vault has, their sizes, and when they changed. File names are encrypted, but the folder depth is visible. Shared read-only links are not end-to-end encrypted, because the person opening the link does not have your key.

Account security

Protect your Quill Cloud account with two-factor authentication. Quill supports authenticator apps and hardware security keys. When two-factor authentication is on, signing in on a new device requires the second factor, and you receive an email listing the device name and approximate location. The account page shows every signed-in device and lets you sign any of them out remotely.

Plugins and security

Plugins run with the permissions you approve when enabling them. Community plugins are reviewed before they are listed, but a review cannot guarantee that a plugin is free of bugs. Grant the network permission only to plugins you trust, because a plugin that can read notes and make network requests could send your notes elsewhere. Plugins installed manually from outside the directory are not reviewed at all.

Data retention and deletion

You can export all of your data from the account page at any time, as a zip file of Markdown files and attachments. Deleting your account removes your notes from the Quill Cloud servers within 30 days, including backups. Billing records are kept for seven years where tax law requires it, but they contain no note content.

Reporting a vulnerability

If you find a security problem, please report it privately to the security team rather than opening a public issue. The security page on the Quill website lists the contact address and the public key for encrypted email. Reports are acknowledged within three working days, and researchers who report valid issues are credited in the release notes unless they prefer to stay anonymous.